steamgears.eu målt mod køreplanen for nye sites

Målt: 8/11 2026, 20:35–20:45 UTC · **Metode:** uautentificerede HTTP-kald mod produktion med `curl/8.5.0` (Chrome-UA giver 454 fra Simplys WAF — det er en kendt fælde i dette repo, ikke et fund) · **Mod hvad:** §9 »Server- og sandbox-forhold« i website-guide-2026-11-08.md samt de dele af §12-tjeklisten der kan ses udefra · **Resultat:** 13 af 27 krav opfyldt, 7 mangler, 7 kan ikke afgøres uden adgang til admin, host eller ejer · **Arbejde der kommer ud af det:** 2,9 d i roadmap-band **S5** (10 poster)

0. Kort udgave

- **Det vigtigste gab er ikke en header — det er at der ingen sandkasse findes.** `staging.`, `dev.` og `test.steamgears.eu` peger alle på produktionens IP via et wildcard, og certifikatet dækker kun `steamgears.eu` og `www.steamgears.eu`, så et subdomæne ikke engang kan åbnes. Hele staging-halvdelen af køreplanen er derfor uafprøvet: ingen test af betalinger, ingen test af databasekopi, ingen accept-port før live.
- **To brugernavne er offentligt læsbare** gennem `/wp-json/wp/v2/users` (`humle91`, `juno`), og `?author=1` redirecter til en indekseret forfatterside. Sammen med `generator`-metaet (WordPress 7.1.4) og en tilgængelig `readme.html` er det den slags oplysninger et automatiseret angreb bruger til at vælge mål.
- **XML-RPC er tændt.** `POST /xmlrpc.php` svarer med metodeliste inkl. `system.multicall` og `pingback.ping`, som er den klassiske vej uden om et login, der ellers er blokeret af WAF'en (455).
- **Klik-hijacking er muligt på alle salgssider.** `/my-account/` sender `X-Frame-Options: SAMEORIGIN` og `frame-ancestors 'self'`, men `/`, `/shop/`, `/faq/`, `/cart/` og `/checkout/` sender ingen af dem. Inkonsistensen beviser, at headeren «kan» sættes — den bliver bare ikke sat der hvor pengene er.
- **REST-indekset er 1,4 MB og 1 193 ruter, og det caches i et år.** `cache-control: max-age=31536000` på `/wp-json/` betyder at en ruteændring kan være usynlig for en klient i op til et år, og svaret tager 4,1–5,2 s at hente. Det er både en hygiejne- og en integrationsrisiko.
- **Det der er i orden, er i orden:** HTTPS med HSTS (1 år, `includeSubDomains`, `preload`), http→https og www→apex som 301, `nosniff`, brotli og gzip, `noindex` på REST, kurv/kasse/konto som `private`, `no-cache`, ægte 404 (ingen soft-404), kataloglistning blokeret (403), SPF med `-all`, og DMARC på `p=reject`.

1. Hvad der blev målt

Flade	Hvordan	Begrænsning
Statuskoder og redirects	ét kald pr. sti, ingen auth, ingen cache-busting	kun stier jeg kendte
Hoveder og cookies	curl -D på forside, shop, kurv, kasse, konto	anononym session sætter ingen cookies
TTFB og størrelse	to kald pr. sti med 1 s mellemrum	fra denne VM, ikke fra Danmark
REST-flade	/wp-json/ hentet og talt, udvalgte namespaces probet	ruter ≠ tilladelser
DNS og mail	DoH mod Cloudflare for TXT, MX og A	kun offentlige records
Sandkasse	DNS-opslag + TLS-håndtryk på fire subdomæner	en sandkasse kan være låst bag andet domæne

Ikke målt: alt der kræver wp-admin, MCP-token eller hostpanel. Der er 0 repository-secrets og intet token i denne sandkasse (målt 8/11), så `WP_DEBUG`, cron, object cache, backupstatus og betalingsindstillinger kan ikke læses herfra. Det er ikke det samme som at de er i orden — det betyder at de står som »kan ikke afgøres« i tabellen nedenfor, og at de skal verificeres én gang via MCP eller hostpanelet.

2. Køreplanen mod målt tilstand

Krav (§9)	Målt 8/11	Status
HTTPS på hele sitet	http:// → 301 til https://, HTTP/2, alt-svc: h3	opfyldt
HSTS	max-age=31536000; includeSubDomains; preload	opfyldt
Kanonisk vært	www → 301 til apex	opfyldt
Ingen debug-output	0 forekomster af Warning/Notice/Fatal i HTML	opfyldt
Logfiler utilgængelige	/wp-content/debug.log og /.htaccess → 455 fra WAF	opfyldt
Kataloglistning blokeret	/wp-content/uploads/ → 403	opfyldt
Rigtige 404	ukendt sti og papirkurvs-id → 404	opfyldt
Kompression	br når klienten beder om det, ellers gzip	opfyldt
nosniff	x-content-type-options: nosniff	opfyldt
Kurv, kasse og konto ikke cachet	cache-control: no-cache, must-revalidate, max-age=0, private	opfyldt
REST indekserbar	x-robots-tag: noindex på /wp-json/*	opfyldt
SPF	v=spf1 include:spf.simply.com -all	opfyldt
DMARC	p=reject (via Simplys record)	opfyldt, se S5.7
Brugernavne ikke læsbare	/wp-json/wp/v2/users svarer 200 med 2 brugere; ?author=1 → 301 til /author/humle91/ (200, indekseret)	mangler
Versionsoplysning væk	generator = WordPress 7.1.4 på alle sider; /readme.html svarer 200	mangler
XML-RPC slået fra	POST /xmlrpc.php svarer med system.multicall, pingback.ping m.fl.	mangler
Klik-hijacking blokeret	frame-ancestors/X-Frame-Options kun på /my-account/, ikke på /, /shop/, /cart/, /checkout/	mangler
Permissions-Policy	ingen header nogen steder	mangler
Stærk Referrer-Policy	no-referrer-when-downgrade (lækker fuld URL til samme scheme)	mangler
Sandkasse findes og er isoleret	staging./dev./test. → samme IP som produktion, certifikat dækker dem ikke (TLS-fejl)	mangler
WP_DEBUG slået fra	kan ikke læses udefra	kan ikke afgøres
DISALLOW_FILE_EDIT	kan ikke læses udefra	kan ikke afgøres
WP_ENVIRONMENT_TYPE=production	kan ikke læses udefra	kan ikke afgøres
System-cron kører	kan ikke læses udefra (repoet ved at DISABLE_WP_CRON er sand og at en kicker kaldes)	kan ikke afgøres
Backup og testet restore	kan ikke læses udefra	kan ikke afgøres

Krav (§9)	Målt 8/11	Status
DKIM	default._domainkey findes ikke — selectoren er en anden	kan ikke afgøres
Betaling i test kontra live	kan ikke læses udefra	kan ikke afgøres

Regnestykket: 27 rækker: 13 opfyldt, 7 mangler, 7 kan ikke afgøres udefra. De 13 er ikke en sejr — de er den del af køreplanen en anonym klient kan bekræfte. Resten kræver adgang, og det er netop de poster S5 samler.

3. De seks fund, med bevis

3.1 Der findes ingen sandkasse

```
staging.steamgears.eu -> 94.231.103.182   (samme IP som produktion)
dev.steamgears.eu     -> 94.231.103.182
test.steamgears.eu    -> 94.231.103.182
TLS: subject=CN=steamgears.eu | SAN: steamgears.eu, www.steamgears.eu
curl: (60) no alternative certificate subject name matches 'staging.steamgears.eu'
```

Wildcard-DNS peger alt på produktionens server, og certifikatet nævner kun apex og `www`. Et nyt subdomæne arver altså DNS med det samme, men fejler på TLS, indtil nogen opretter det og får et certifikat. Praktisk betydning: hver ændring på sitet er i dag en ændring i produktion. Det er den samme tilstand som køreplanen kalder den dyre fejl — ikke fordi koden er dårlig, men fordi der ikke er noget sted at prøve den.

3.2 Brugernavne og version er offentlige

```
GET /wp-json/wp/v2/users?per_page=100 -> 200, 2 rækker: (1, humle91, Humle91), (2, juno, Juno)
GET /?author=1                        -> 301 /author/humle91/
GET /author/humle91/                  -> 200, 99 010 bytes, meta robots = follow, index
GET /                                  -> <meta name="generator" content="WordPress 7.1.4">
GET /readme.html                      -> 200
```

Login er blokeret af WAF'en (455), så oplysningerne er ikke i sig selv et indbrud. Men de giver et brugernavn at gætte adgangskoder på, en WordPress-version at slå CVE'er op i, og en forfatterside der konkurrerer med de rigtige sider i søgeresultaterne (den er `index`, ikke `noindex`). Det er billigt at lukke: Rank Math kan fjerne `generator`, REST-brugerendpointet kan kræve auth, `readme.html` kan fjernes, og forfatterarkivet kan sættes til `noindex`.

3.3 XML-RPC er åbent ved siden af et lukket login

```
GET  /xmlrpc.php  -> 405, allow: POST
POST /xmlrpc.php  -> 200 med system.multicall, system.listMethods, pingback.ping,
demo.addTwoNumbers ...
```

`system.multicall` er præcis den metode der gør XML-RPC attraktiv til at afprøve mange kodeord i ét kald. WAF'en blokerer `/wp-login.php`, men rører ikke `/xmlrpc.php`. Det er en ulukket dør ved siden af en lukket.

3.4 Klik-hijacking-beskyttelsen stopper ved kassen

Side	X-Frame-Options	frame-ancestors
/	—	—
/shop/	—	—

Side	X-Frame-Options	frame-ancestors
/cart/	—	—
/checkout/	—	—
/my-account/	SAMEORIGIN	'self'

At konto-siden har dem viser, at det tekniske er på plads — det er WooCommerce, der sætter dem på netop den side. Resten står åbent for indramning, og kassen er den side hvor en indrammet side kan få en kunde til at trykke på noget andet end hun tror. `Permissions-Policy` mangler helt, og `Referrer-Policy` er den svageste nyttige værdi.

3.5 REST-indekset er stort, langsomt og cachet i et år

```
GET /wp-json/ -> 200, 1 465 070 bytes, 1 193 ruter, TTFB 0,83-1,01 s, total 4,06-5,16 s
cache-control: max-age=31536000 | expires: 2027-11-08
namespaces: mwai 126 ruter | wc/v3 133 | wc/store 62 | google-site-kit 60 | mcp 28 | wp/v2 ...
```

Ruterne er ikke i sig selv en tilladelse — `wc/v3`, `wp/v2/settings` og `mwai/v1/mcp/status` svarer 401, og `novamira/...` svarer 403, hvilket er korrekt. Problemet er de tre ting sammen: indekset vejer 1,4 MB, tager fire-fem sekunder, og må caches i et år. Et års cache på en rute fortegnelse betyder at en fjernet eller tilføjet endpoint ikke forsvinder for en klient, og at en proxy kan servere en gammel liste længe efter en opdatering.

3.6 Mail-identiteten er halvt på plads

```
TXT steamgears.eu        -> "v=spf1 include:spf.simply.com -all"      (stram, god)
TXT _dmarc.steamgears.eu -> "v=DMARC1; p=reject; rua=mailto:dmarc@robot.simply.com; ..."
TXT default._domainkey   -> findes ikke
MX                       -> 10 mx.simply.com
```

`p=reject` er den stramme indstilling, og SPF'en afviser alt andet end Simply. Men aggregatrapporterne går til Simplys robot og ikke til butikken, så ingen her ser hvem der sender i domænets navn, og DKIM-selectoren er en anden end `default` og blev derfor ikke fundet. Det er en opgave for hosten, ikke for koden.

---

4. Hvad der ikke kan afgøres udefra

Disse står som »kan ikke afgøres« i §2, og de er ikke dermed i orden. De kræver et af tre: MCP-token, hostpanel eller ejerens oplysninger.

Spørgsmål	Hvor svaret findes	Hvem
Er WP_DEBUG, WP_DEBUG_DISPLAY og DISALLOW_FILE_EDIT sat rigtigt?	wp config get via MCP	agent
Står WP_ENVIRONMENT_TYPE på production?	wp eval via MCP	agent
Kører cron, og hvem kalder den?	wp cron event list + repoets kicker	agent
Er der object cache, og virker den?	hostpanel / Site Health	ejer
Hvornår blev en backup sidst gendannet?	hostpanel	ejer
Hvilken DKIM-selector bruger Simply?	hostpanel / DNS	ejer
Kan staging oprettes, og med hvilken DB-kopi?	Simplys kontrolpanel	ejer
Står betalinger i live-tilstand i produktion?	WooCommerce → betalinger	ejer

---

5. Køreplanen oversat til S5 (2,9 d)

#	Post	Hvorfor nu	Effort
S5.1	Sandkasse hos Simply: subdomæne, certifikat, egen databasekopi, HTTP-auth, noindex, WP_ENVIRONMENT_TYPE=staging, testnøgler til Stripe	uden den er hver ændring en produktionsændring	0,75 d
S5.2	Produktionskonfigurationen verificeret: WP_DEBUG=false, WP_DEBUG_DISPLAY=false, DISALLOW_FILE_EDIT=true, miljøtype, cron, object cache, debug-log uden for webroot	køreplanens baseline er i dag en antagelse	0,30 d
S5.3	Identitets- og versionslækager lukket: generator-meta, /wp/v2/users, ?author=, readme.html, forfatterarkiv til noindex	to brugernavne og en version er gratis at fjerne	0,30 d
S5.4	Sikkerhedsheaders ens på alle sider: frame-ancestors/X-Frame-Options, Permissions-Policy, Referrer-Policy: strict-origin-when-cross-origin	kassen er i dag indrammelig	0,20 d
S5.5	XML-RPC slået fra, WAF-dækning bekræftet	åben dør ved siden af et lukket login	0,15 d
S5.6	REST-fladen ryddet: færre namespaces, max-age ned fra et år, indekset under 1 s TTFB	1,4 MB og et års cache er en integrationsfælde	0,30 d
S5.7	Mail-identitet færdig: DKIM-selector fundet og verificeret, DMARC-rapporter til egen adresse	p=reject uden rapporter er blind	0,15 d
S5.8	Backup og restore øvet: RPO/RTO skrevet ned, én gendannelse ført til staging	køreplanens måltal kræver et målt tal	0,25 d
S5.9	Deploy-gate og rollback: branch protection, manuelt promote-trin, release-tag, skrevet rollback-rutine	GitHub-beskyttelse virker ikke på et privat Free-repo	0,25 d
S5.10	Miljøværn i CI: de 13 målte krav som natligt tjek, så et register ikke rådner stille	det der måles i dag, måles ikke i morgen	0,25 d
S5 total			2,90 d

Status samme aften (8/11): S5.3–S5.6 er kodet i `wordpress/mu-plugins/sgap-hardening.php` med **44 offline-assertions** i `wordpress/tests/test-hardening.php` (nu værn i den natlige kørsel), og målingen er gjort kørbar som `tools/s5_measure.py` — 20 rækker, der skriver `reports/s5-status-<dato>.md`. Pluginnet kan **ikke** lægges på sitet herfra: der er hverken MCP-token, CLI eller repository-secrets i sandkassen (målt 8/11). Den ene ejerhandling er at uploade filen til `wp-content/mu-plugins/`, slette `readme.html` og derefter køre `python3 tools/s5_measure.py --strict`; den skal give **0 mangler** før posterne er lukket.

Rækkefølge: S5.1 og S5.2 først — de er forudsætningen for at de øvrige kan «bevises» i stedet for at blive påstået. Derefter de fire der kan gøres uden ejeren (S5.3–S5.6), så mail og backup (S5.7–S5.8, kræver hostpanelet), og til sidst porten og værnene (S5.9–S5.10). S5.1 er **ejer-blokeret** indtil subdomænet findes hos Simply; resten kan agenten udføre, når der er adgang.

---

6. Sådan genskabes målingen

```
UA='curl/8.5.0'   # Chrome-UA giver 454 fra WAF'en

curl -sSI https://steamgears.eu/ | grep -iE 'strict-transport|x-content-type|referrer-policy'
curl -sS -o /dev/null -w '%{http_code}\n' https://steamgears.eu/wp-json/wp/v2/users
curl -sS -o /dev/null -D - https://steamgears.eu/wp-json/ | grep -iE 'cache-control|expires'
curl -sS -o /dev/null -w '%{http_code} %{size_download}\n' 'https://steamgears.eu/?author=1'
XML='<?xml version="1.0"?><methodCall><methodName>system.listMethods</methodName>'
curl -sS -X POST --data "$XML<params/></methodCall>" https://steamgears.eu/xmlrpc.php | head -c 200
for h in staging dev test; do curl -sSI "https://$h.steamgears.eu/" 2>&1 | head -2; done
```

Køres den igen efter S5, skal de syv »mangler«-rækker i §2 skifte til »opfyldt«, og antallet af »kan ikke afgøres« skal falde til nul.

7. Forbehold

- Målingen er gjort fra denne VM, ikke fra Danmark. TTFB-tallene er derfor et relativt mål, ikke en Core Web Vitals-måling.
- Ruter i `/wp-json/` er ikke det samme som tilladelser. De namespaces der blev probet, afviste korrekt.
- Et 455-svar fra WAF'en beviser at stien er blokeret, ikke at filen ikke findes.
- `p=preload` i HSTS-headeren er en anmodning, ikke en bekræftelse på at domænet står på browsernes preload-liste.
- Der er ikke målt Lighthouse, GA4 eller ordredata i denne runde.

Kilder: §9 og §12 i website-guide-2026-11-08.md · WordPress' dokumentation for `wp_get_environment_type()` og debugging · WooCommerce' testordrer og WooPayments' migreringsdokumentation (alle listet i guidens §15) · egne målinger 8/11 2026.